

PHOTAAZ

Production Readiness and Package QA Runbook

Step-by-step staging validation, billing tests, legal readiness, and
launch checklist

Version 1.0 | 3 August 2026

Based on the current **bs-photos-hub** plan configuration and application review

Release rule: Do not launch merely because the pages look complete. Launch only after security isolation, payment lifecycle, media storage, package boundaries, legal disclosures, backups, and rollback all pass with evidence.

1. Executive answer: is the app complete?

Feature coverage is substantial, but the platform is **not yet production-complete solely from UI completion**. A photographer SaaS that handles accounts, public portfolios, uploaded images, inquiries, custom domains, and payments also needs enforceable authorization, reliable billing state, durable media storage, operational controls, and legal documents matched to the real data flow.

Current stop-ship items

- Prove server-side super-admin authentication and role authorization. A client-side localStorage gate is not a security boundary.
- Every customer read and mutation must prove that the signed-in user owns or is authorized for the requested tenant. A tenant slug alone is insufficient.
- Onboarding and checkout must not create or upgrade arbitrary tenants supplied by the browser.
- Production uploads must use configured Cloudinary storage; local server-disk fallback is unsafe on most deployments.
- Unknown public tenant slugs must return a real not-found response instead of demo content.
- Record repeatable tests for high-risk flows before release.

Definition of done: every critical case in this runbook is PASS, severity-1 and severity-2 defects are closed, database restore is rehearsed, and a controlled production smoke test succeeds.

2. Package source-of-truth matrix

Feature	Free	Plus	Pro	Ownership
Price	\$0	\$19 monthly / \$190 annual	\$49 monthly / \$490 annual	\$1,490 one time
Blogs	3	10	50	Unlimited
Total photos	50	300	5,000	Unlimited
Hero images	1	3	5	Unlimited
Photos per category	20	50	500	Unlimited
Parent categories	3	10	20	Unlimited
Subcategories per parent	3	5	10	Unlimited
Galleries	3	10	50	Unlimited
Photos per gallery	20	50	500	Unlimited
Premium themes	0	2	5	Unlimited
Category requests	0	5	20	Unlimited
Custom domain	No	Yes	Yes	Yes
Page-header images	No	Yes	Yes	Yes
Theme components	No	Yes	Yes	Yes
Watermark	No	No	Yes	Yes
Advanced customization	No	No	No	Yes
Any-language localization	No	No	No	Yes
Grace period	0 days	7 days	14 days	Lifetime / none

Theme access note

Lumen is the basic Free theme. Archive, Noir, Contact Sheet, and Monogram are premium. Atelier and Horizon are special themes intended for Pro and Ownership. The current logic combines tier permission, a numeric premium-theme allowance, and catalog order. Test the exact visible and selectable theme list for Plus and Pro and confirm it matches the intended commercial promise.

3. Staging setup and test evidence

Use production-like staging

- Separate staging PostgreSQL/Supabase database with a restorable snapshot.
- Paddle Sandbox with sandbox price IDs and webhook endpoint.
- Separate Cloudinary cloud or environment-specific folder.
- Resend test sender/domain and controlled inbox.
- HTTPS staging hostname with production-like root-domain routing.
- Never use production secrets or real customer data in staging.

Create isolated personas

Persona	Plan or state	Purpose
qa-admin	Super admin	Admin authorization and platform content
qa-free	Free	Every Free boundary
qa-plus	Plus active	Plus limits and billing
qa-pro	Pro active	Pro and watermark
qa-owner	Ownership	Unlimited and lifetime
qa-grace	Plus and Pro overdue	Grace windows
qa-expired	Expired paid plan	Safe downgrade
qa-attacker	Ordinary user	Cross-tenant negative tests

Record evidence

Test ID	Build	Expected	Actual	Status	Evidence / bug
PKG-F-01	commit SHA	50th upload succeeds			screenshot + log
SEC-TEN-01	commit SHA	Tenant B denied			HTTP response
BILL-WH-01	commit SHA	Event applied once			event ID + DB row

4. Exact boundary-testing method

Apply to every numeric limit

- Prepare the account at limit minus one. Use controlled fixtures for large Pro counts.
- Perform the last allowed action through the real UI; it must succeed.
- Repeat once; it must fail with a clear upgrade message.
- Bypass the UI and submit the underlying request directly; the server must still reject it.
- At the limit, edit, reorder, and delete must remain usable.
- Delete one counted record and retry; creation should work.
- Upgrade and retry without signing out; entitlement must refresh safely.
- Downgrade with excess content; records stay stored while creation and public visibility follow the effective plan.

Decisions to document

Area	Current behavior to verify	Decision needed
Blogs	All tenant blog records appear to count	Should drafts count?
Category requests	All submitted records may count	Do rejected requests free capacity?
Photos	Overall and per-category checks both apply	Which error takes priority?
Themes	Tier + count + catalog ordering	Which exact themes are promised?
Downgrade	Records retained; visibility limited	Which retained records remain visible?

5. Free package execution

- Create blogs 1-3; Blog 4 fails. Delete one; its replacement succeeds.
- Upload photos 1-50; Photo 51 fails. In one leaf category, Photo 20 succeeds and 21 fails.
- Create three parent categories; the fourth fails. Create three children under one parent; the fourth fails.
- Create three galleries; the fourth fails. Add 20 photos to a gallery; the twenty-first fails, including assignment of an existing photo.
- Lumen works; every premium/special theme is rejected server-side.
- Custom domain, category request, page-header image, theme components, and watermark are unavailable.

For every case: verify the UI state, server response, database count, public-site result, notification, and audit/log evidence.

6. Plus package execution

- Repeat boundaries at 10 blogs, 300 photos, 3 hero images, 50 photos/category, 10 parents, 5 children/parent, 10 galleries, and 50 photos/gallery.
- Category requests 1-5 work; request 6 fails.
- Custom domain, page-header images, and theme components work; watermark remains unavailable.
- Exactly two premium themes plus the basic theme are accessible; special themes remain denied.
- Test monthly and annual checkout, seven-day grace, cancellation, expiry, and renewal restoration.

For every case: verify the UI state, server response, database count, public-site result, notification, and audit/log evidence.

7. Pro package execution

- Use fixtures for 50 blogs, 5,000 photos, 5 hero images, 500 photos/category, 20 parents, 10 children/parent, 50 galleries, and 500 photos/gallery.
- Category requests 1-20 work; request 21 fails.
- Custom domain, page-header images, theme components, and watermark work.
- Test watermark position, opacity, size, text, background, public delivery, disable/restore, and tenant isolation.
- Verify five non-basic themes according to catalog order and the intended special-theme access.
- Test monthly and annual checkout, fourteen-day grace, expiry, and renewal.

For every case: verify the UI state, server response, database count, public-site result, notification, and audit/log evidence.

8. Ownership package execution

- Treat null numeric limits as unlimited, never zero.
- Create beyond Pro limits with no limit rejection.
- Confirm all coded themes, custom domain, watermark, advanced customization, and any-language localization.
- Validate the \$1,490 lifetime transaction and ensure no recurring expiry is introduced.
- Two months of free maintenance is an operational benefit, not an access expiration.
- Replay the webhook; no duplicate entitlement or payment record.

For every case: verify the UI state, server response, database count, public-site result, notification, and audit/log evidence.

9. Billing and subscription lifecycle

- Test Plus and Pro monthly and annual checkout, plus Ownership lifetime checkout.
- Test success, failure, abandonment, duplicate event, delayed event, update, cancellation, past-due, resume, and expiry.
- Valid Paddle signatures succeed; missing, invalid, or body-tampered signatures return 401.
- A transaction upgrades only the authorized tenant and stores correct customer, subscription/transaction, price, status, and dates.
- Duplicate webhook delivery is idempotent.

Expected effective access

Subscription state	Expected access
No subscription	Free
ACTIVE / TRIALING	Paid plan
PAST_DUE within period or grace	Paid plan with warning
Plus overdue days 1-7	Plus during grace
Plus overdue day 8+	Expired; effective Free
Pro overdue days 1-14	Pro during grace
Pro overdue day 15+	Expired; effective Free
CANCELED / EXPIRED and unusable	Effective Free
Ownership	Lifetime; no recurring expiry expected

Downgrade preservation

Create more content than Free permits and enable paid settings. After expiry, database counts remain unchanged; excess content and paid settings become locked or hidden, never deleted. Renewing restores them with stable ordering. Grace and expiry notification/email should occur once.

10. Security release gate

- Unauthenticated visitors cannot call dashboard or admin mutations.
- User A cannot read, edit, delete, upload to, bill, or configure User B tenant by changing a slug or record ID.
- Admin pages and actions require a real authenticated admin role; localStorage manipulation has no effect.
- Onboarding cannot upsert arbitrary users or tenants.
- Checkout cannot attach a purchase to another customer.
- Webhook and cron endpoints reject invalid secrets.
- Upload validation checks real content, MIME, dimensions, and size server-side.
- Rate limits cover sign-in, signup, contact, support, inquiry, upload, and sensitive mutations.
- Secrets never appear in client bundles, logs, errors, or source control.
- Unknown tenant slugs return 404; suspended-tenant behavior is deliberate.

Automatic NO-GO: any cross-tenant access, admin bypass, payment misattribution, secret exposure, or webhook forgery.

11. Legal and compliance - required before launch

For this SaaS, legal pages are not optional decoration. They set the contract with photographers and visitors, disclose data use, clarify image ownership, and support payment-provider requirements. A qualified lawyer should adapt them to your operating country and customer markets.

Document	Minimum coverage
Privacy Policy	Account/profile data, uploaded-media metadata, inquiries, payment identifiers, cookies, purposes, legal bases where applicable, processors, transfers, retention, rights, security, children, contact, and changes.
Terms of Service	Eligibility, accounts, plans and limits, acceptable use, billing, renewals, cancellation, suspension, intellectual property, availability, warranties, liability, indemnity, termination, governing law, and disputes.
Refund and Cancellation	Monthly, annual, and lifetime refund rules; timing; access through the paid term; grace period; downgrade; chargebacks; and Paddle merchant-of-record wording if applicable.
Cookie Policy and consent	Necessary, analytics, and marketing cookies; vendors; duration; controls; consent banner where required; and withdrawal.
Acceptable Use Policy	Illegal, abusive, exploitative, hateful, infringing, malware, spam, impersonation, scraping, and prohibited photographic content; enforcement and reporting.
Copyright / IP Policy	Photographer ownership; limited hosting/display license; rights and release warranties; takedown process; counter-notice; repeat-infringer policy.
Data Processing Addendum	Business-customer processing roles, security, subprocessors, deletion, transfers, breach support, and audit/assistance commitments.
Subprocessor List	Hosting, database, media, payment, email, analytics, and monitoring vendors; purpose, location where known, and update method.

Priority: Privacy Policy, Terms of Service, Refund/Cancellation Policy, Cookie Policy/consent, Acceptable Use, and Copyright/Takedown should be live before accepting public customers.

12. Legal product controls and photography clauses

Controls that make the documents real

- Show Terms and Privacy links before signup and in every public footer.
- Use an unticked acceptance checkbox; record user ID, timestamp, document version, locale, and IP where lawful.
- Notify users of material changes and collect renewed acceptance where required.
- Provide verified access/export, correction, deletion, and objection/opt-out handling.
- Define retention for inactive accounts, inquiries, tickets, logs, media, backups, and payment records.
- Account deletion explains billing cancellation, media deletion timing, backup retention, and irreversible effects.
- Publish a takedown contact and internal response workflow.
- Marketing consent is separate from operational email.

Photography-specific clauses

- Photographers retain ownership and must have permission for every image.
- Users are responsible for model/property releases, trademarks, and sensitive content.
- Photaaz receives only the limited license needed to store, transform, watermark, back up, and display content.
- Disclose temporary persistence in backups or CDN caches after deletion.
- Explain public indexing, custom domains, downloads, and that watermarks do not prevent copying.
- Define reports, removals, counter-notices, and repeat-infringer handling.

Legal QA

ID	Test	Expected
LEG-01	Open all legal links on desktop/mobile/locales	Correct version; no 404
LEG-02	Sign up without accepting	Blocked
LEG-03	Inspect acceptance audit row	Version and time saved
LEG-04	Withdraw optional cookies	Non-essential tracking stops
LEG-05	Request export/deletion	Verified workflow completes
LEG-06	Submit copyright notice	Case recorded and routed
LEG-07	Cancel paid plan	UI matches published policy

13. Full product validation

- Test marketing, theme, blog, legal, auth, onboarding, dashboard, admin, and public tenant routes on desktop, tablet, and mobile.
- Test English, Urdu, Spanish, Arabic, Turkish, Hindi, Portuguese, German, and French; inspect Urdu/Arabic RTL and localized metadata.
- Confirm main-site blogs are managed from the super-admin blog module: create, translate, publish, schedule, edit, and remove.
- Only approved/published tenant media and posts appear publicly.
- Test JPG, PNG, WebP, corrupt files, invalid MIME, exact size limit, over-limit, Unicode names, and extreme dimensions.
- Production never silently stores uploads on ephemeral local disk.
- Verify robots.txt, sitemap.xml, feed.xml, manifest, canonicals, alternate locales, Open Graph, Twitter cards, and structured data.
- Run keyboard, focus, contrast, label, alt-text, error, zoom, and screen-reader smoke checks.
- Run performance smoke and Lighthouse on marketing and public tenant pages.
- Simulate database, Cloudinary, Paddle, and email outages; errors must be safe and data must remain consistent.

14. Deployment sequence

1. Freeze features and record the release commit.
2. Back up staging and rehearse restore.
3. Close every security stop-ship item.
4. Run install, Prisma generation, lint, type-check, production build, and smoke tests.
5. Complete Free, Plus, Pro, and Ownership boundary suites.
6. Complete Paddle checkout, webhook, cancellation, grace, expiry, downgrade, and renewal suites.
7. Complete cross-tenant and admin authorization tests.
8. Complete legal review and acceptance/audit controls.
9. Complete all-language, RTL, responsive, accessibility, SEO, media, email, and failure-mode checks.
10. Provision production database and apply reviewed migrations; do not use ad-hoc schema push as the production migration strategy.
11. Configure production Cloudinary, Paddle, email, domains, secrets, cron, monitoring, and backups.
12. Deploy privately and run production smoke tests.
13. Create one controlled Free tenant and perform one controlled real payment.
14. Verify webhook, entitlement, email, logs, SSL, sitemap, and rollback readiness.
15. Obtain named engineering, product, security, legal, and operations sign-off; then announce launch.

15. Final go/no-go sign-off

Release gate	Owner	Status	Evidence
Production build passes		PASS / FAIL	
Reviewed database migrations applied		PASS / FAIL	
Free boundaries pass		PASS / FAIL	
Plus boundaries pass		PASS / FAIL	
Pro boundaries pass		PASS / FAIL	
Ownership lifetime behavior passes		PASS / FAIL	
Checkout and webhook idempotency pass		PASS / FAIL	
Cancellation, grace, expiry, downgrade, and renewal pass		PASS / FAIL	
Customer ownership enforced server-side		PASS / FAIL	
Admin role enforced server-side		PASS / FAIL	
Cross-tenant negative suite passes		PASS / FAIL	
Cloudinary has no local fallback		PASS / FAIL	
Backups and restore rehearsal pass		PASS / FAIL	
Core legal policies published		PASS / FAIL	

Release gate	Owner	Status	Evidence
Consent and policy-version evidence recorded		PASS / FAIL	
Privacy request and account deletion tested		PASS / FAIL	
All locales and RTL checked		PASS / FAIL	
Responsive and accessibility checks pass		PASS / FAIL	
SEO and metadata pass		PASS / FAIL	
Monitoring, alerts, runbook, and rollback owner confirmed		PASS / FAIL	
Controlled production smoke and payment pass		PASS / FAIL	

Decision

Decision	Name	Date	Notes
GO / NO-GO			

Legal note: This is a technical and operational checklist, not legal advice. Obligations depend on company location, customer markets, payment structure, analytics, marketing, user age, and the personal data processed. Use counsel to finalize legal text.